

MFA rollout communications plan — Halden Distribution Ltd.

Owner: IT (Muhammad Ibrahim Akmal) · **For:** all staff, via department heads · **Date:** 2026-10-02

Related: docs/runbooks/mfa-and-conditional-access.md , configs/conditional-access/ , configs/auth-methods-policy.json

Why this document exists: the technical part of MFA is a few policy settings. The part that decides whether the rollout succeeds is communication and support. Microsoft's own research shows MFA cuts account-compromise risk very substantially, but a rollout where 20% of staff cannot sign in on the first morning is a business outage, not a security win.

1. Rollout in stages (not a big-bang)

Stage	Who	Duration	What IT watches
1. Internal	IT team (5 accounts)	2 days	Enrolment works; nothing breaks
2. Pilot	One volunteer department (HR, 4 accounts)	3–5 days	Sign-in logs; how many helpdesk calls
3. All staff	Everyone else	over 1 week, in department groups	Helpdesk call volume; enrolment completion

At every stage the policies start in **report-only**. That means they record what *would* have happened without blocking anybody. Only once the pilot shows the right people being challenged and the exempt accounts not being challenged are the policies turned on.

The order that prevents a lock-out: create the two emergency ("break-glass") accounts first, keep them excluded from every policy, then enable. The design is documented in docs/00-design.md §7.

2. Staff email (send 5 working days before each group's change)

Subject: Action needed: setting up two-step sign-in (takes 5 minutes)

Hello,

On **[date]** we are adding a second step to signing in at Halden, called two-step sign-in (MFA). From then on, after entering your password you will approve a prompt on your phone. This is the single most effective thing we can do to stop someone using a stolen password to read our email and files.

What you need to do — about 5 minutes, before [date]:

1. Install the **Microsoft Authenticator** app from your phone's app store (free).
2. On your work computer, go to **aka.ms/mfasetup** and sign in.
3. Follow the prompts to scan the code with the app. When it says "number matching", you will see a

two-digit number on your screen to type into the app — that is correct, it stops someone approving a sign-in that is not yours.

1. That is it. Next time you sign in, approve the prompt.

If you get stuck: contact the Service Desk. We have extra people on during the rollout and will not leave anyone stuck on the first morning.

Thank you — IT

3. One-page setup guide (attached to the email, printable)

Setting up two-step sign-in in 5 minutes

1. **Get the app.** App Store (iPhone) or Google Play (Android) → search **Microsoft Authenticator** → Install → Open.

1. **Open the setup page.** On your work computer, in a browser, go to **aka.ms/mfasetup**.

2. **Add a method.** Choose **Add sign-in method** → **Authenticator app** → **Add**.

3. **Scan the code.** In the app, tap + → **Work or school account** → **Scan QR code**, then point your phone at the code on the screen. *(If you cannot use the camera, choose "Enter code manually".)* **Do not share or photograph this QR code** — it is the same as your password for this purpose, and it is enrolled once only.

1. **Approve the test.** The app shows a number; type it into the prompt on your computer.

2. **Done.** Next sign-in, approve the prompt.

3. **Going somewhere with no signal?** Set up a backup: ****aka.ms/mfasetup** → Add sign-in method → Authenticator app**, or ask IT for a temporary pass before you travel.

Frequently asked questions

I do not have a smartphone. Tell the Service Desk. There is an alternative, and you will not be expected to buy a phone.

I changed phones / lost my phone. Contact the Service Desk immediately — we will reset your method after confirming who you are. Do not try to set it up again yourself while locked out.

It keeps asking every time. That is normal for a new device or a new location; it settles down. It is a security feature, not a fault.

I am worried about my privacy. The app does not read your messages or your location. It only receives the sign-in approvals you make.

Can I use a text message instead? Not if it can be avoided: codes sent by text can be intercepted. The app is the recommended method at Halden.

What if I approve a prompt I did not start? Tell the Service Desk straight away — it means someone else has your password, and we will reset it and revoke your sessions.

Will this stop me working while travelling? Set up a backup method before you travel, and tell the Service Desk your dates so we can check your access before you go.

4. Helpdesk surge plan

Item	Plan
Extra cover	Service Desk adds cover on each group's change day (morning, the peak)
Fastest fix	If a user cannot approve: issue a Temporary Access Pass so they can sign in and re-enrol, rather than resetting their password
Priority	Locked-out users first, questions second
Script	"Is the app installed? Can you see a number to type? Are you on Wi-Fi or mobile data?"
Escalation	Two consecutive failures on the same account → check for a policy problem before treating it as user error
Evidence	Keep a daily count of calls per department — that count is the rollout's real result and goes in the KPI report

5. What good looks like

- Every user is enrolled **before** the policy is enforced for their group.
- The emergency accounts are still able to sign in with a password alone (verified deliberately).
- Legacy sign-in attempts (old mail clients using saved passwords) are blocked and visible in the logs.
- Helpdesk calls per department fall back to normal within a week of each group's change.

6. What we will not do

- We will not turn on a policy for a group whose training email has not gone out.
- We will not enable enforcement before reviewing the report-only sign-in logs.
- We will not present the rollout as "0% disruption". The honest measure is how many calls it

generated and how quickly they were resolved — and that number comes from the helpdesk count, not from optimism.

Lab note: Halden Distribution Ltd. is a **fictional company**, the 85-person staff file is **synthetic**, and this guide is written for a lab project. No real staff are affected by it, and no real QR code, seed or recovery code is ever stored in this repository (AGENTS.md rule R3).